

# “We Have Never Been Attacked”

Unpacking the Illusion of Cybersecurity in Small Business

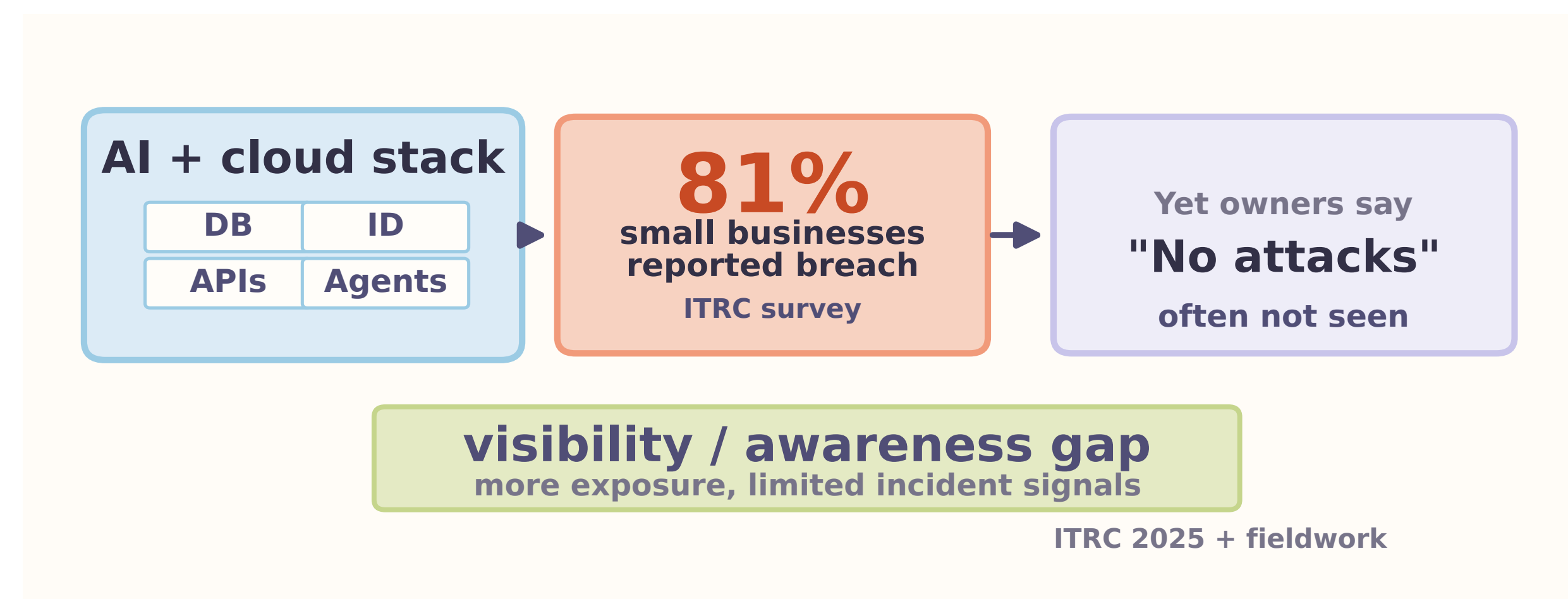
Chi Zhang<sup>1</sup>, Ping Ji<sup>1,2</sup>, and Zhengfan Zhang<sup>3</sup>

<sup>1</sup>The Graduate Center, CUNY   <sup>2</sup>Hunter College, CUNY   <sup>3</sup>New York University  
CHI.ZHANG06@gc.cuny.edu   ping.ji@hunter.cuny.edu   zz4657@nyu.edu

## Why This Is Important Now

**AI lowers the cost of building technical companies.**

- Founders can combine cloud databases, hosted identity, APIs, and AI workflows.
- Tiny teams can handle regulated documents, user data, code, and secrets before hiring security staff.



## Main-Study Data Sources

**128** participants  
**102** startup owners  
**10** deep interviews

**Scope:** small businesses with 1–500 employees.

**Interviews** 8 owners/employers + 2 employees

**Surveys** 7 owners + 9 employees

**Intercepts** 102 startup owners from multiple countries

**Recruitment** convenience sampling via networks (interviews); online maker communities (surveys); international tech expo (intercepts)

**Duration** interviews: 30–45 min; intercepts: ~10 min

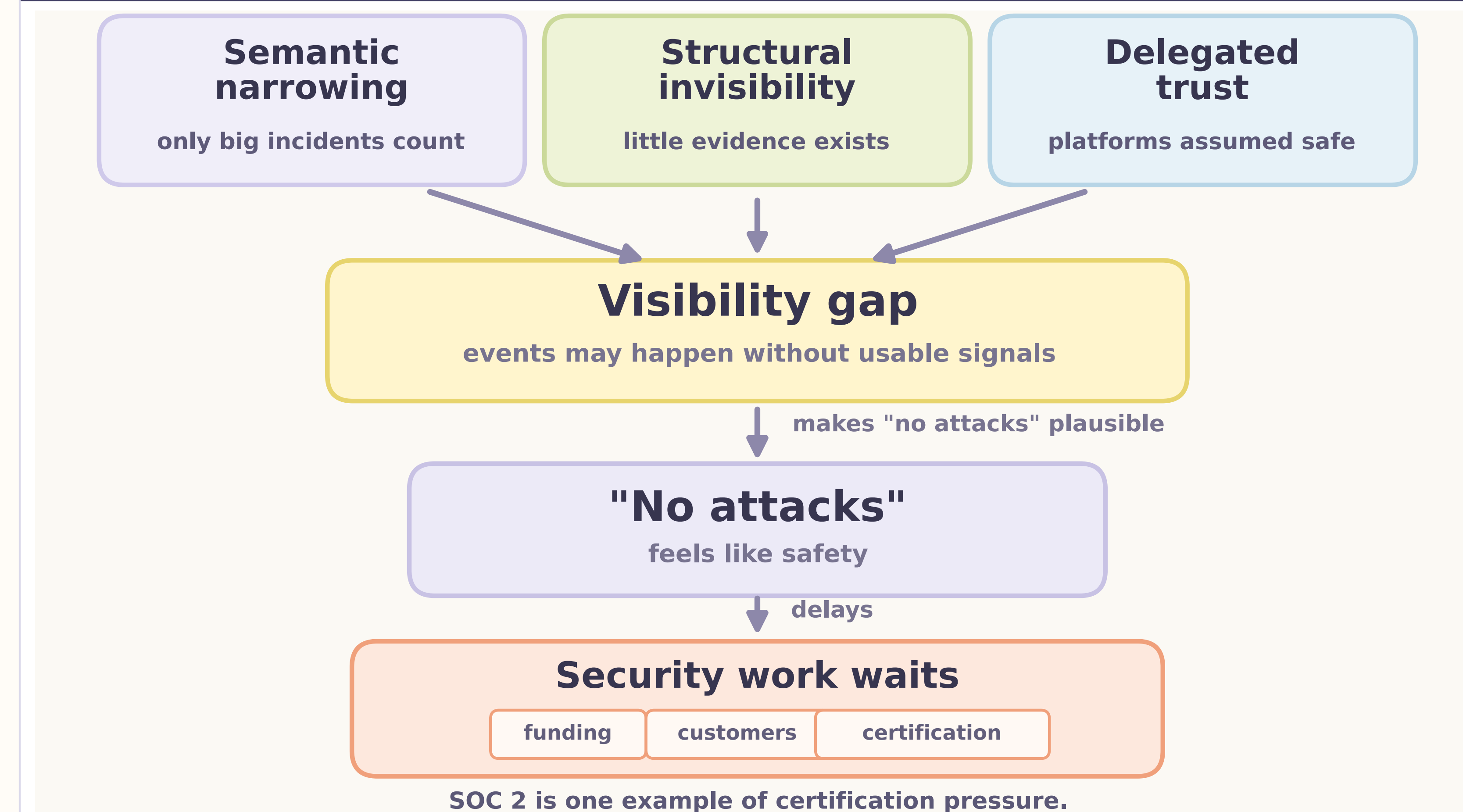
**Ethics**

CUNY HRPP/IRB approved. Consent obtained; findings reported in de-identified form.

## What We Ask

**When a small business reports “no attacks,” does that reflect evidence or limited visibility?**

## Core Finding



## Mentalities Behind “No Attacks”

- Semantic narrowing** Attacks are defined as catastrophic breaches, so routine suspicious activity does not count.
- Structural invisibility** Missing logs, alerts, and monitoring make incidents hard to see and hard to remember.
- Delegated trust** Cloud, SaaS, and platform defaults are treated as if they cover the whole security boundary.

## What Actually Moves Security Work

- Awareness gap** Routine threats are often invisible until translated into business loss.
- External trigger** Security investment often starts with funding, investor diligence, or enterprise-customer pressure.
- Certification** SOC 2 is one example: certification becomes a market-access requirement, not just a technical best practice.

## Two Supplemental AI-Startup Cases

Separate from N=128; about one week of direct founder engagement per case.

### Case 1: Regulated-Document AI Company

- 5-person team with regulated documents and health data.
- **Flow:** cloud storage → processing → external AI.
- **Trigger:** compliance review prompted access controls, audit logs, and expert review.
- **Gaps:** de-identification, data controls for external AI, and recovery.

### Case 2: AI Agent-Evaluation Company

- 3-person team evaluating agents with public benchmarks and private data.
- **Flow:** code repositories → cloud → chat integrations.
- **Risk:** access control, credentials, data origins, and disclosure.
- **Governance:** manual checks and platform defaults.

## Implications

**Small-business security is not enterprise security made smaller.**

Tiny AI-enabled teams need support that makes everyday risk visible before a breach narrative exists.

- Default-on audit logs and suspicious-activity signals.
- Clear cloud/SaaS responsibility boundaries.
- Secret/API inventories, revocation trails, and recoverable evidence.

## Selected References

- [1] AI Index Steering Committee. *AI Index Report 2026: Economy*. Stanford HAI, 2026.
- [2] Identity Theft Resource Center. *2025 Business Impact Report*. ITRC, 2025.
- [3] N. Huaman et al. “A Large-Scale Interview Study on Information Security in and Attacks against SMEs.” *USENIX Security*, 2021.